Atomic, Correlation, Anomaly

The Layers of a Robust Detection

Gabriel Novaes



$whoami

Gabriel Novaes @s1moesz 🇧🇷

- Content Engineer at TryHackMe
  - Leading DE learning (cools things coming soon)
- 6 years as Lead Detection & Hunting Engineer at iT.eam (MSSP)
- Passions:
  1. Research the DE Process
  2. Running (in mountains)
     - 3 marathons
     - 1 ultra (176km - TMB)



Overview

How can we build good detections?

1 - Why a detection fail?

2 - What are the components of a robust detection?

3 - How can we do a good detection research? ✦ (Main topic)

4 - What is the best strategy for my detection logic?

> **“If I had eight hours to chop down a tree, I’d spend the first six of them sharpening my axe”**

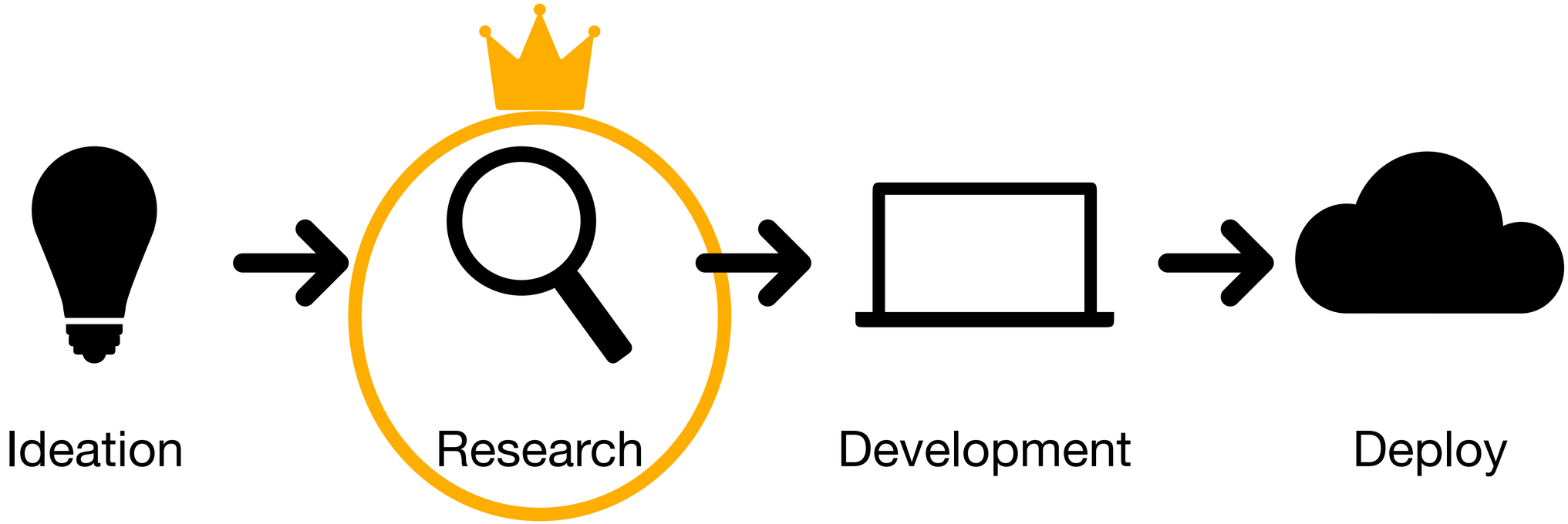


What Is a Detection Rule?

(Hey advanced guy, please don’t skip this)

Detection Rules

"Detection rules are predefined conditions that automatically analyze security data (telemetry) to identify suspicious activity and trigger alerts for investigation."



Why Detections Fail

A real-world pain



Hey,
The SOC team is drowning in alerts nobody trusts, and last month an attacker dumped credentials on a finance workstation without a single alert firing.

Why?

Tom - SOC Manager

Let’s investigate!

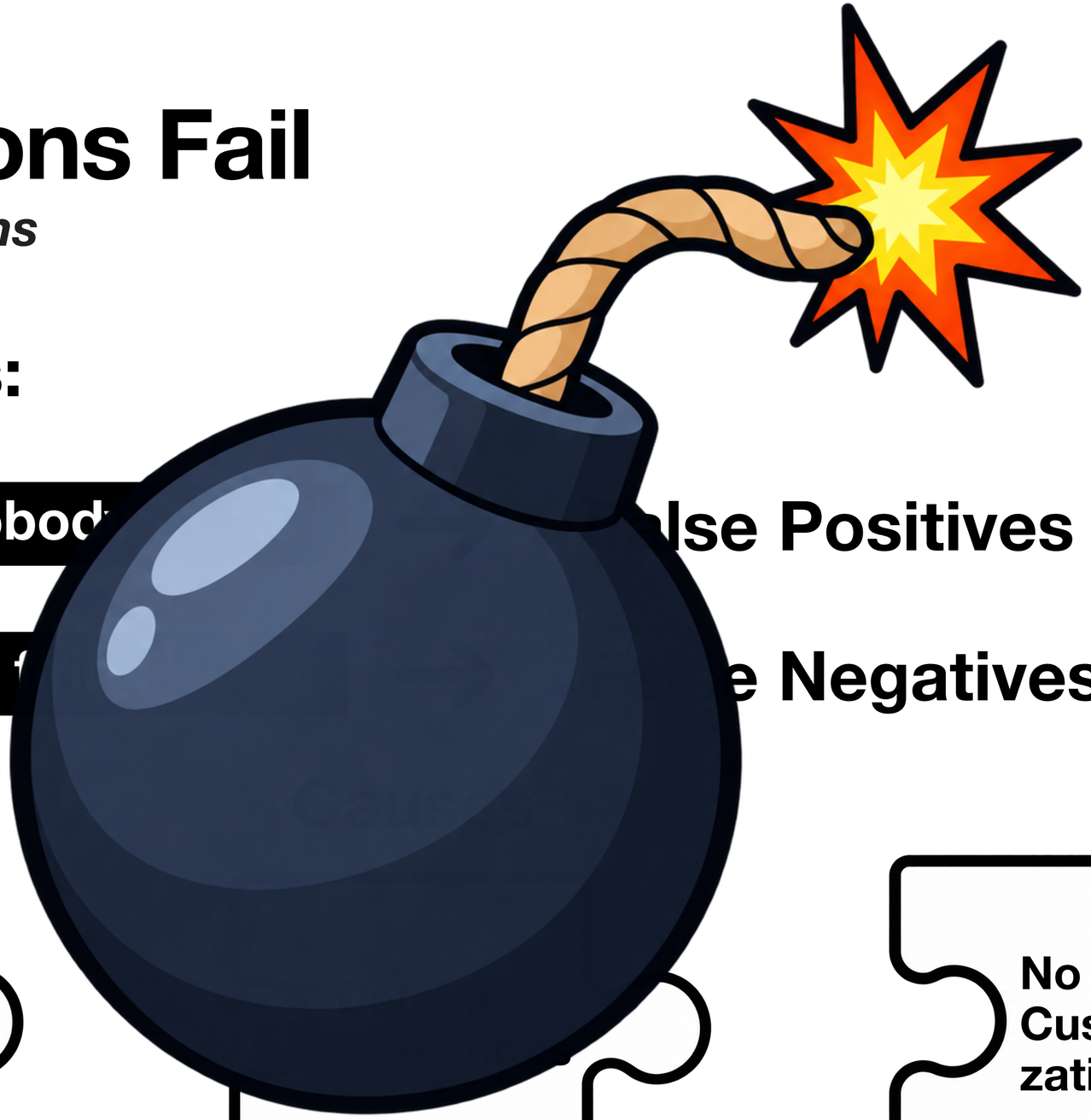
Why Detections Fail

Identifying the symptoms

Tom's Complaints:

"drowning in alerts nobod lse Positives

“without a single alert e Negatives



Public Detections

No Customi-zation

Why Detections Fail

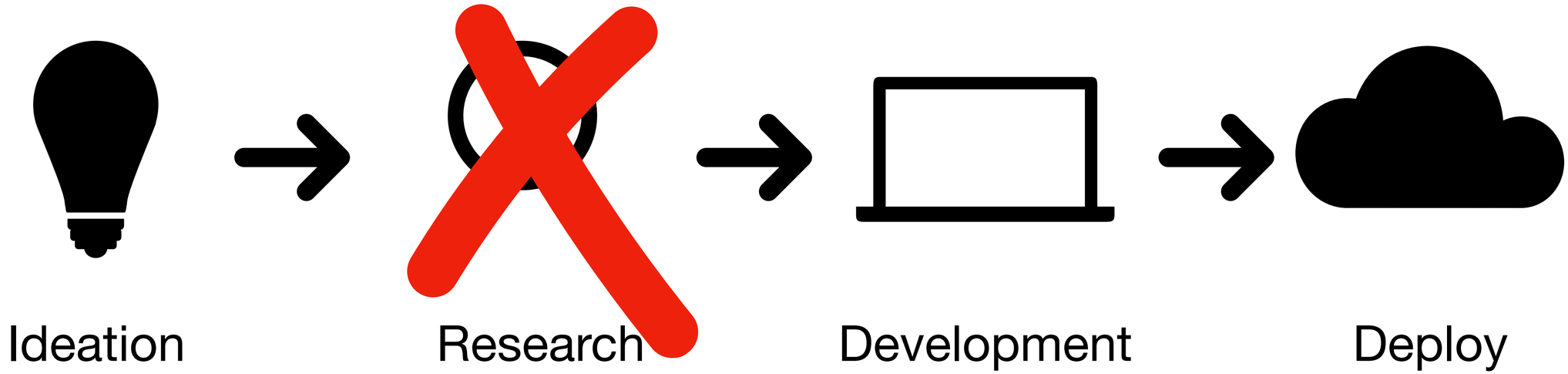
The Hidden Problems

- The same public detections you have access, **the attackers can study them**
  - They want to **hide in legitimate data**
- If you don’t baseline, **generic detections will generate noise**
  - Some behaviors **can be ambiguous** (benign and malicious)

If you don’t understand how normal looks, you can’t understand the attacker’s behavior.

Why Detections Fail

Research is not just about the threat, it's also about knowing your environment.



Why Detections Fail

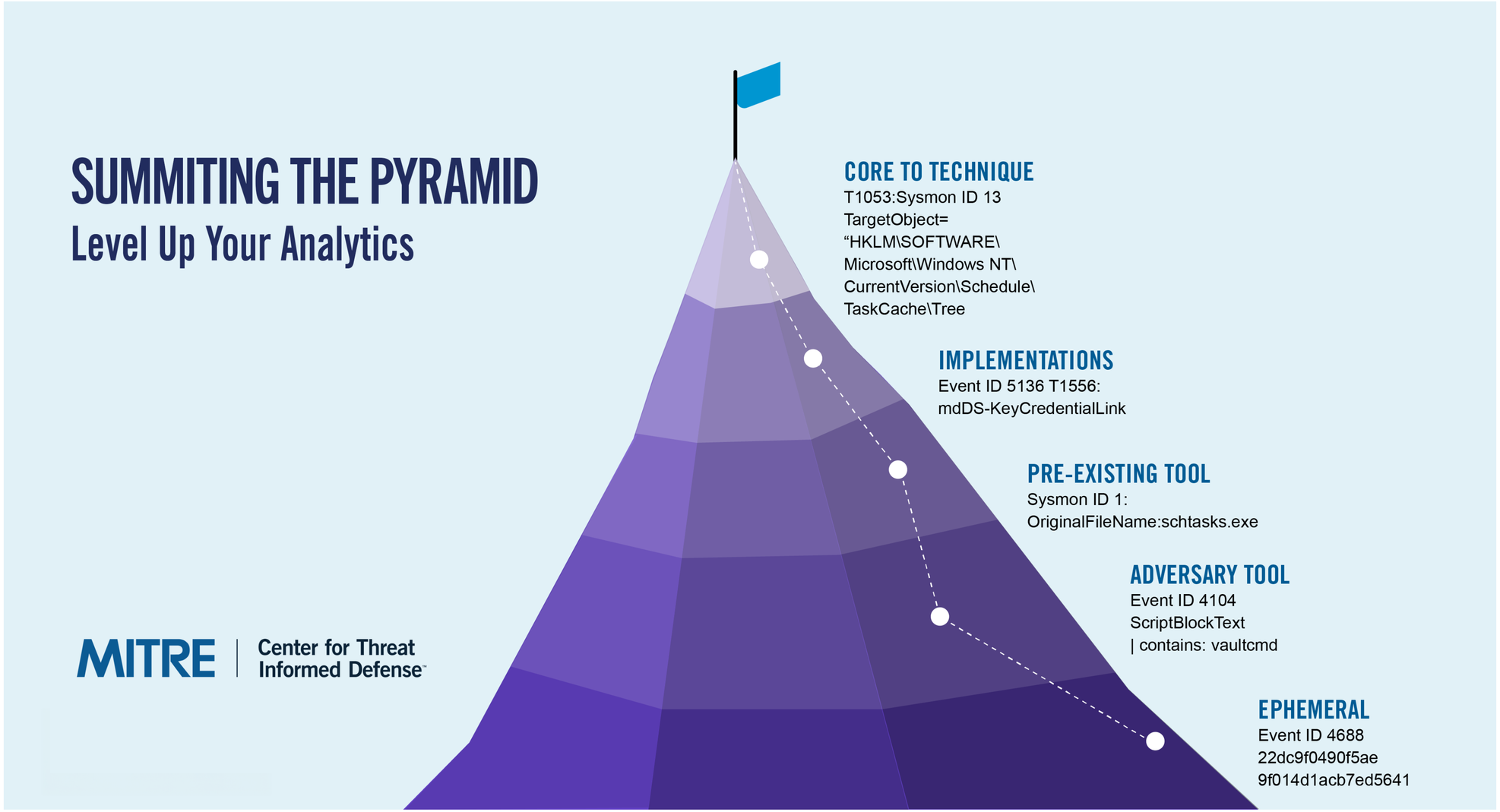
Why Good Research is Hard?

- Time pressure
- Good research is invisible
- Research has no natural end
- Techniques can be wide

What Makes a Good Detection?

(Or Robust?)

First…



https://center-for-threat-informed-defense.github.io/summiting-the-pyramid/

Components of a Good Detection

Core Definition

Robustness

A robust detection is one that has high accuracy and is resistant to adversary evasion over time.

```
detection:
    selection:
        Image|endswith: '\powershell.exe'
        CommandLine|contains: '-EncodedCommand'
    condition: selection
```

```
detection:
    selection_image:
        - Image|endswith:
            - '\powershell.exe'
            - '\pwsh.exe'
        - OriginalFileName:
            - 'PowerShell.EXE'
            - 'pwsh.dll'
            - 'pwsh.exe'
    selection_encoded_command:
        CommandLine|re: '(?i)[\x{002D}\x{2013}\x{2014}\x{2015}]e(c|nc*o*d*e*d*c*o*m*m*a*n*d*)*\s+
\"*[a-z0-9/\+]{20,}\=*{0,2}'
    condition: selection_image and selection_encoded_command
```

https://detect.fyi/malicious-encoded-powershell-detecting-decoding-modeling-321fd322c6ec

What Makes a Good Detection?

A good research process!

Components of a Good Detection

The Research Process

Step 1: Understand the Behavior

- **Detection Goal:** Detected Base64 Encoded Commands

```
powershell.exe -EncodedCommand VwByAGkAdABlAC0ASABvAHMAdAAgACIASABlAGwAb
ABvACAAVwBvAHIAbABkACEAIgA=
```



```
Write-Host "Hello World!"
```

- **Why:** Hide Malicious Commands
- **Scope:** Windows Hosts
- **How:** Threat Reports, MITRE ATT&CK, Microsoft Documentation, etc



What are the execution possibilities? (Main Output)

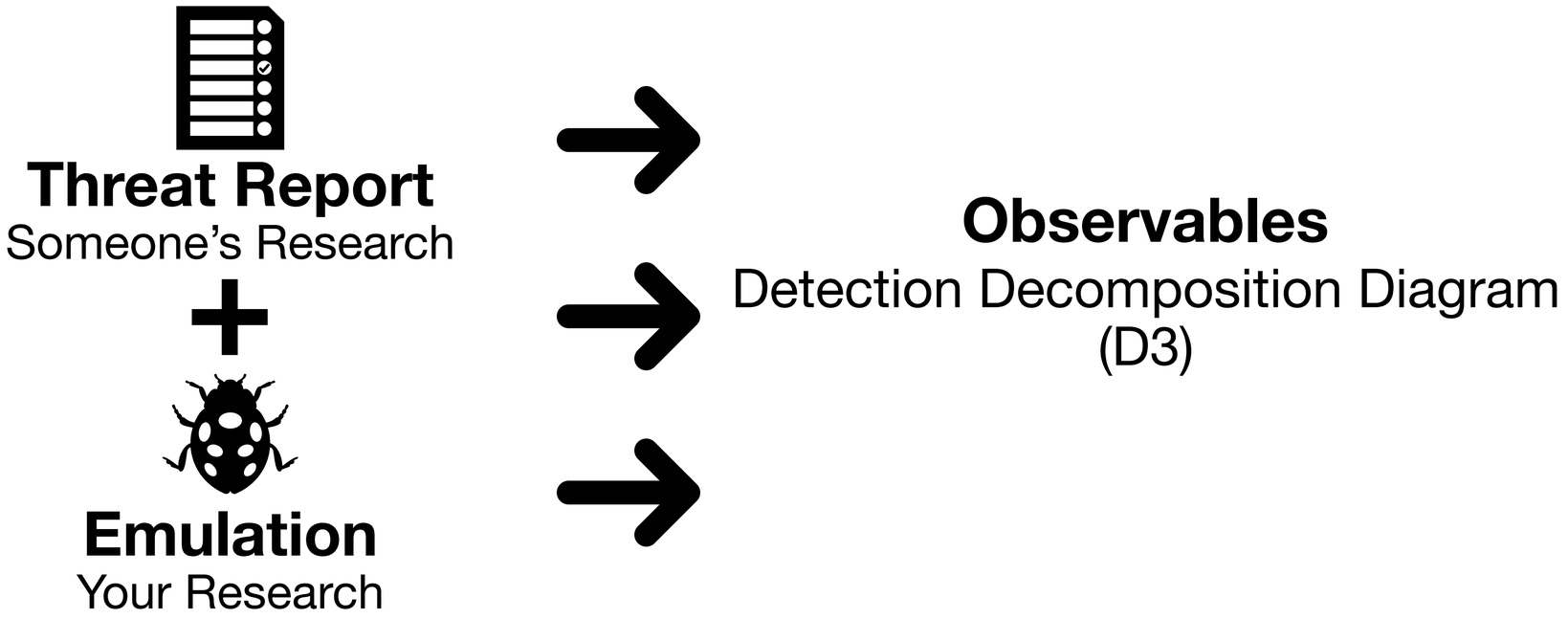
CommandLine (-EncodedCommand) or PS Script (FromBase64…)

Components of a Good Detection

The Research Process

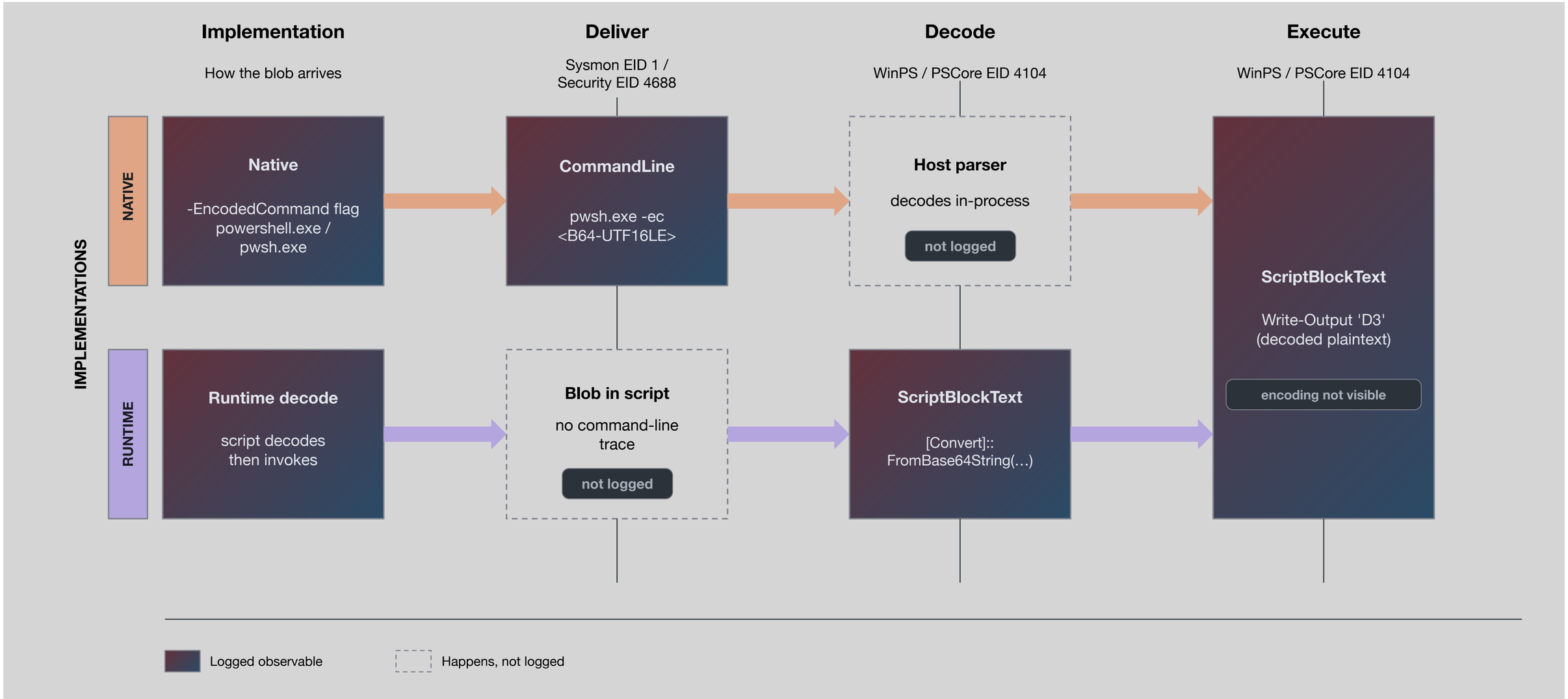
Step 2: Identify Observable Opportunities

- What telemetry the behavior leaves behind?



Components of a Good Detection

Detection Decomposition Diagram (D3)



Components of a Good Detection

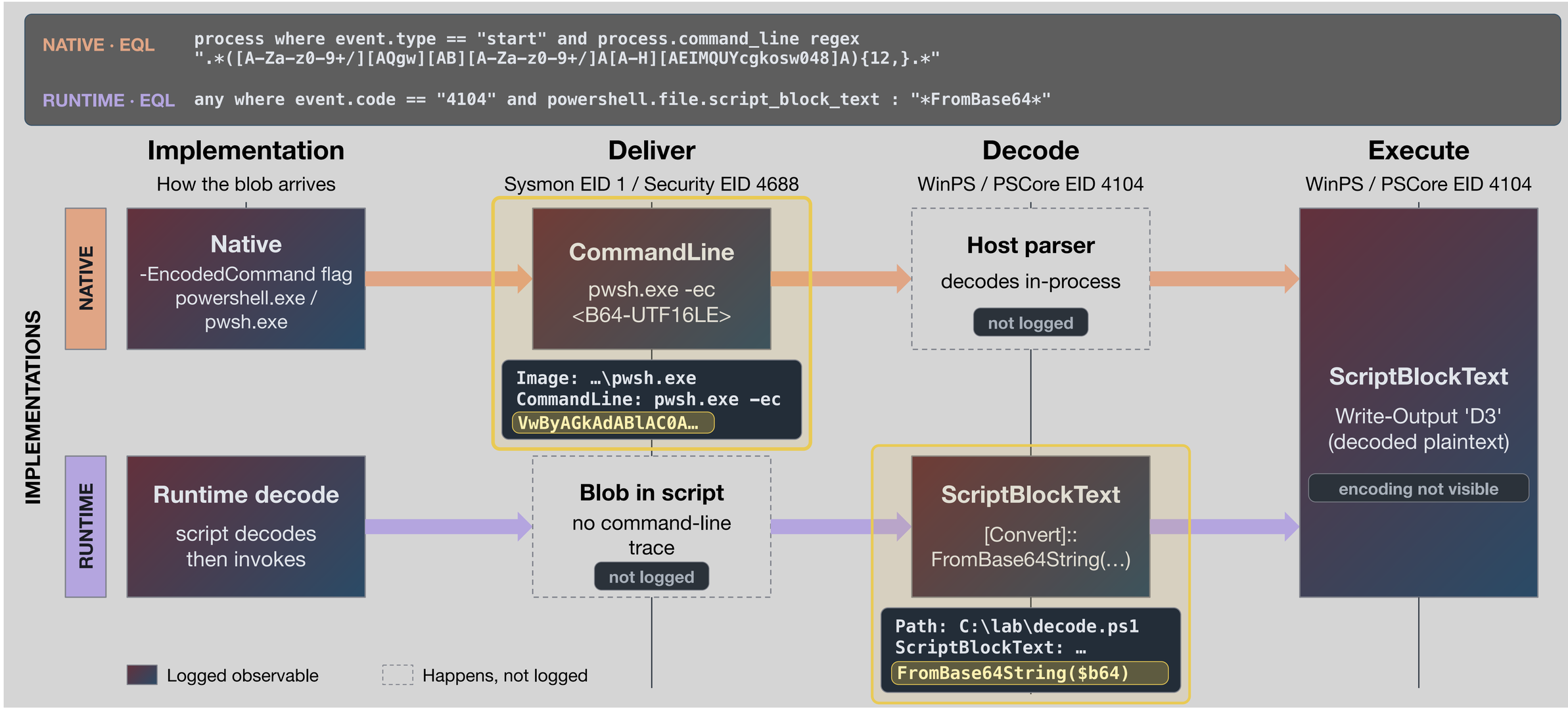
The Research Process

Step 3: Identify Robust Observables

- What observable should my detection rely on?

Components of a Good Detection

The Research Process



Components of a Good Detection

Mapping the Robust Observables - Summiting the Pyramid Methodology

Application (A)	User-mode (U)	Kernel-mode (K)

5 – Core to (Sub-)Technique

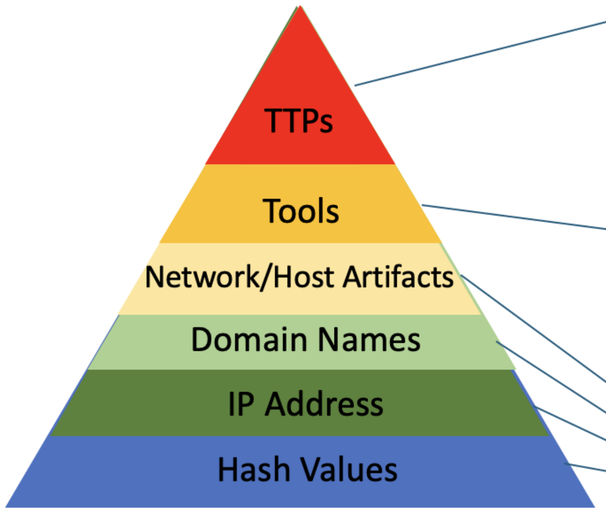
4 – Core to Some Implementations

3 – Core to Pre-Existing Tool

2 – Core to Adversary-Brought Tool

1 – Ephemeral

The Pyramid



Understood As

Behaviors demonstrated by an adversary

Tools used by adversaries during an attack

Ephemeral values which are easy for an adversary to change

Analytic Robustness

Core to (Sub-) Technique (5)

Core to Some Implementation of (Sub-) Technique (4)

Core to Pre-Existing Tools or Inside Boundary (3)

Core to Adversary-Brought Tools or Outside Boundary (2)

Ephemeral (1)

Components of a Good Detection

The Research Process

Step 4: Confirm Data Exists

- Do we have the data (telemetry) to create detections using the observables?
- **Findings:**
  - PowerShell logging not enabled
  - Event ID 4688 enabled, but without command line logging
  - Sysmon installed and working!
- The straight answer: "*Create only the Sysmon based detection.”*
- The **right** answer: “*We **start** with the Sysmon based detection. But, we also **open a ticket** in the backlog to enable PS logging and cmdlines for EID 4688”*

Components of a Good Detection

Defining the Observable to Focus

Final Score: 3K	Application (A)	User-mode (U)	Kernel-mode (K)
5 – Core to (Sub-)Technique			
4 – Core to Some Implementations			
3 – Core to Pre-Existing Tool			**CommandLine -EncodedCommand** full prefix/dash grammar AND OriginalFileName in `(PowerShell.EXE, pwsh.dll)`
2 – Core to Adversary-Brought Tool			
1 – Ephemeral			

Components of a Good Detection

The Research Process

Step 5: Learn How Normal Looks Like

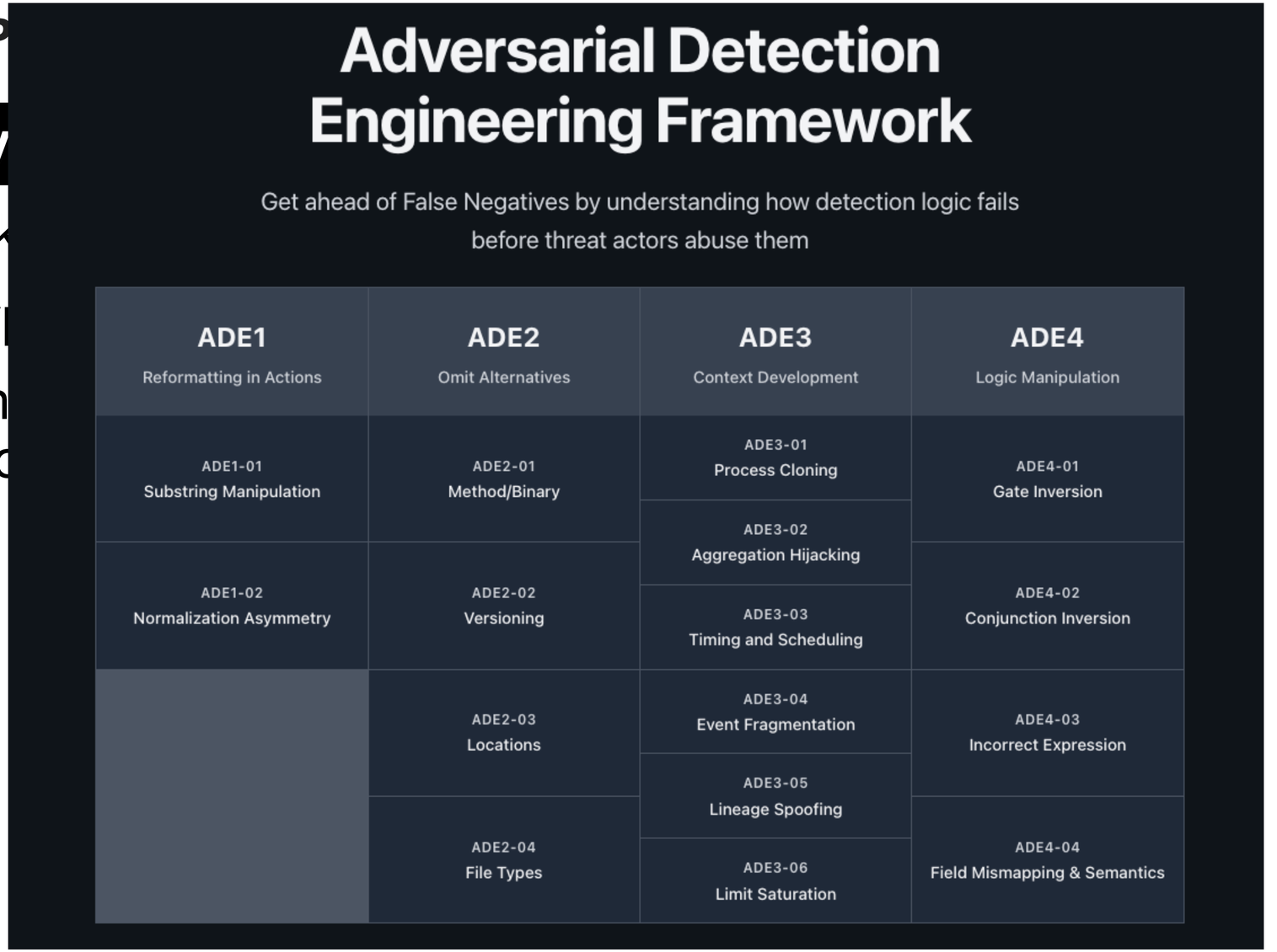
- How is the benign usage of encoded commands within our environment?
- **Findings:**
  - Admin scripts
  - Asset Inventory executable

Components of a Good Detection

The Research P

Step 6: Identify

- How an attack
- Identifying Byp
  - Red Teamin
  - Bug Likeliho

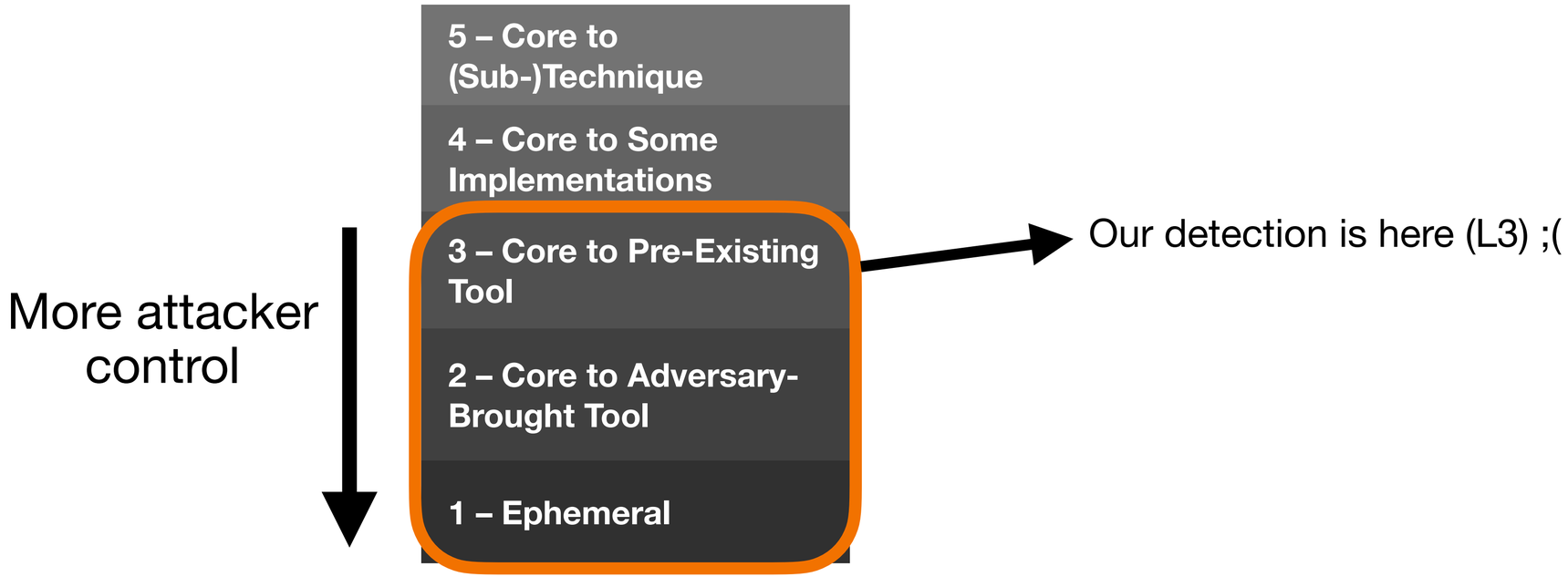


Components of a Good Detection

The Research Process

Step 6: Identify Potential Bypasses

Everything that is under the attacker's control is bypassable!



Components of a Good Detection

The Research Process

Step 6: Identify Potential Bypasses

powershell.exe -EncodedCommand <BASE64STRING>

- pwsh.exe
- myfile.exe

- En Dash: –
- Em Dash: —
- Horizontal Bar: ―
- Slash: /

-ec
-enc
-encode
….

“<BASE64STRING>"

Source: https://detect.fyi/malicious-encoded-powershell-detecting-decoding-modeling-321fd322c6ec

Components of a Good Detection

The Research Process

Step 7: Write the Candidates

Main Logic

```
process where event.provider == "Microsoft-Windows-Sysmon" and event.code == "1" and

 (process.name : ("powershell.exe", "pwsh.exe") or
  process.pe.original_file_name : ("PowerShell.EXE", "pwsh.dll", "pwsh.exe")) and

 process.command_line regex~ """".*[-——]e(clnc*o*d*e*d*c*o*m*m*a*n*d*)* +['']*[a-zA-Z0-9/+]{20,}={0,2}.*"""
```

Filters

```
not (process.parent.executable : """C:\Program Files\Contoso\AssetAgent\AssetAgent.exe""" and
      user.domain == "NT AUTHORITY" and user.name == "SYSTEM" and
      process.command_line : "* -NoLogo -NoProfile -NonInteractive -WindowStyle Hidden -ExecutionPolicy Bypass -EncodedCommand *")

 not (process.parent.command_line : """C:\Windows\system32\svchost.exe -k netsvcs -p -s Schedule""" and
      user.domain == "THREAT-EMULATIO" and user.name == "Administrator" and
      process.command_line : "* -NoProfile -NonInteractive -WindowStyle Hidden -ExecutionPolicy Bypass -enc
IwAgAEMAbwBuAHQAbwBzAG8AIABJAFQAIAAtACAA*")
```

Components of a Good Detection

AI Candidates - GPT 6.1 Sol

Step 7: Write the Candidates

Prompt: “Create a Sigma rule to detect encoded commands in PowerShell”

```
detection:
    selection_image:
        Image|endswith:
            - '\powershell.exe'
            - '\pwsh.exe'
    selection_encoded:
        CommandLine|contains:
            - ' -EncodedCommand '
            - ' -enc '
            - ' -e '
            - ' -ec '
            - ' -enco '
            - ' -encodedc '
    condition: selection_image and selection_encoded
```

Components of a Good Detection

AI Candidates - GPT 6.1 Sol

Step 7: Write the Candidates

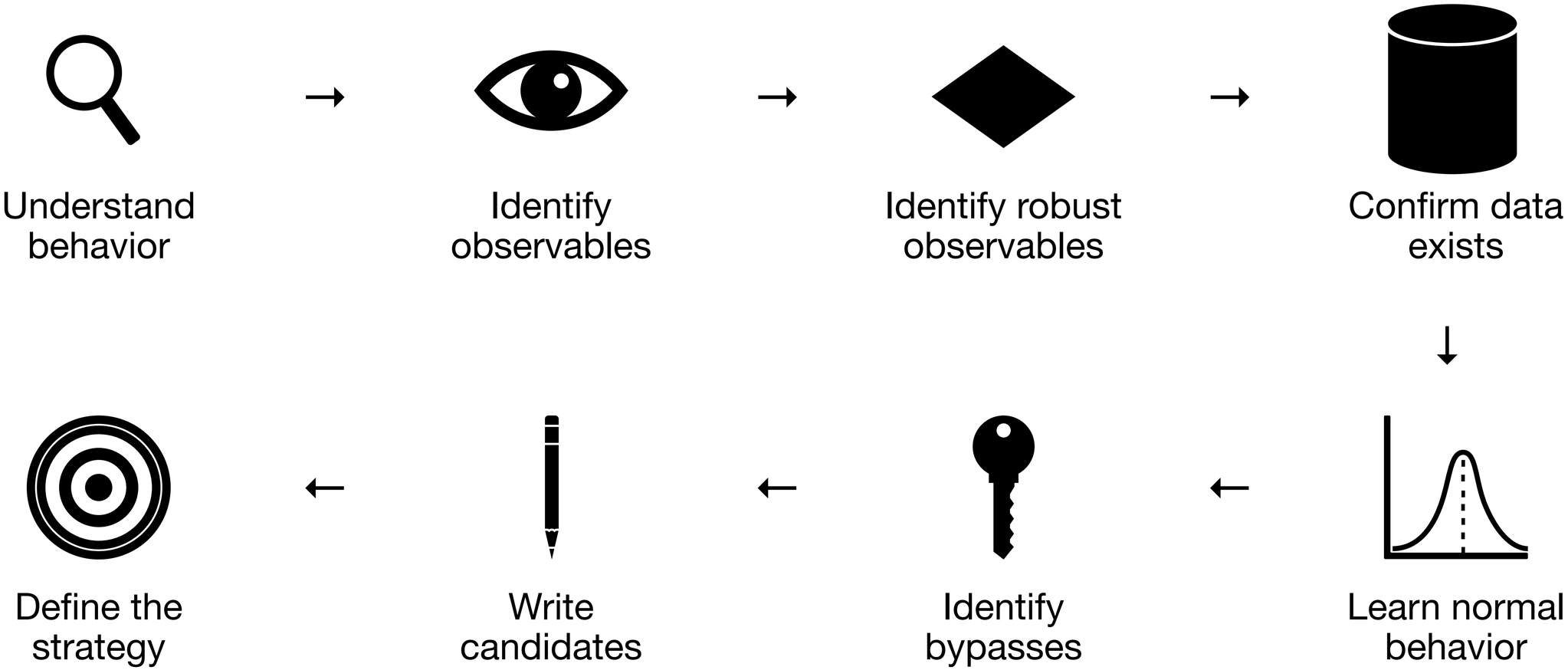
Prompt: “Create a Sigma rule to detect encoded commands in PowerShell”
- Research documentation and references attached to the prompt.

```
detection:
    selection_image:
        Image|endswith:
            - '\powershell.exe'
            - '\pwsh.exe'
    selection_original_filename:
        OriginalFileName:
            - 'PowerShell.EXE'
            - 'pwsh.exe'
    selection_encoded:
        CommandLine|re|i: '(?:^|[ \t])[-/——](?:e|ec|en|enc|enco|encod|encode|encoded|encodedc|encodedco|encodedcom|
encodedcomm|encodedcomma|encodedcomman|encodedcommand)(?:[ \t]|:|$)'
    condition:
        (selection_image or selection_original_filename)
        and selection_encoded
```

Please, don’t just prompt and pray. ***Create research agents!***

Components of a Good Detection

The Research Process



Inspiration: https://center-for-threat-informed-defense.github.io/summiting-the-pyramid/analytic-design/deworkflow/

Step 8: Define the Strategy

Atomic, or Correlation, or Anomaly?

Defining the Strategy

What we got from our research?

- Detection logic to detect encoded commands
  - Filters benign behavior
  - Robust against multiple bypasses

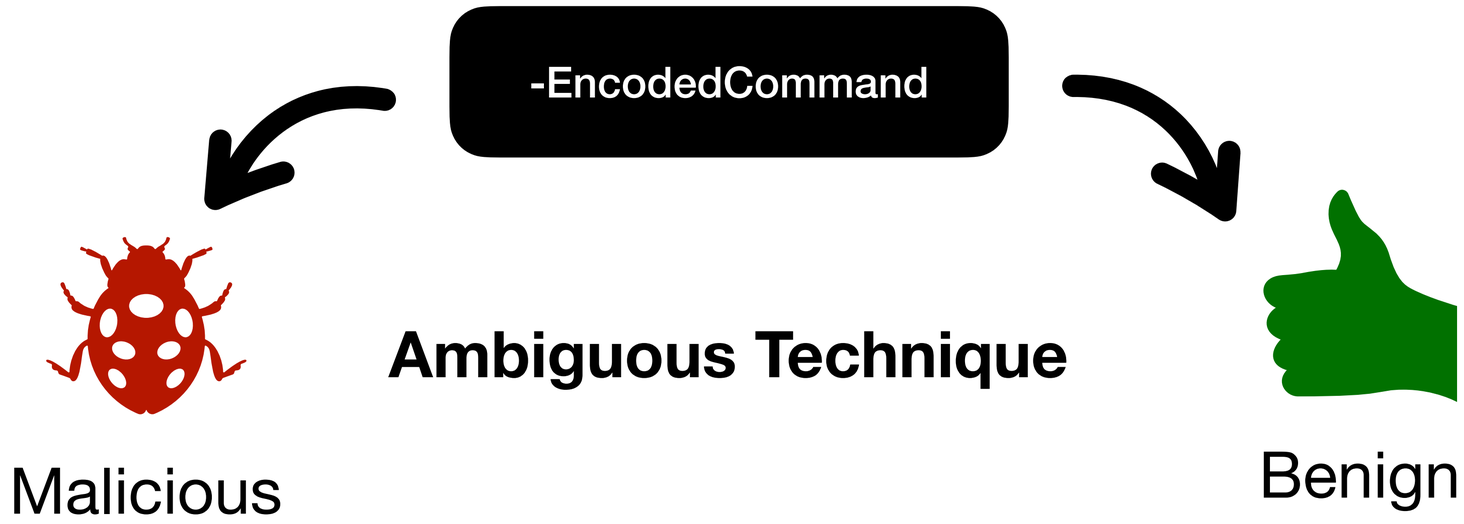
Is a single, specific action or indicator of malicious on its own?

Maybe?

Atomic Rules

Alert on a single event that matches a known bad indicator or behavior

- Examples
  - Mimikatz dump cmd flags
  - IOC matching (e.g. malicious IP, domain, etc)



Atomic Rules

Problems: Ambiguous Techniques

- Are we going to implement infinite filter as our environment changes?

↳ A new tool can be installed tomorrow and it runs encoded commands.

How can I handle those ambiguous behaviors without adding infinite filters?

Context → = Intent

+ Correlation

Correlation Rules

Using Context to Identify Intention

- Malicious Context



Note: This is just a few examples and not a full research project.

Correlation Rules

Using Context to Identify Intention

- Benign Context



Note: This is just a few examples and not a full research project.

Correlation Rules

Alert when multiple conditions match.

- Direct Correlation

  ↳ Technique A **AND** Technique B **AND** Technique C

  - Challenging to implement effectively (not flexible)
  - Harder to maintain
  - Easier to bypass

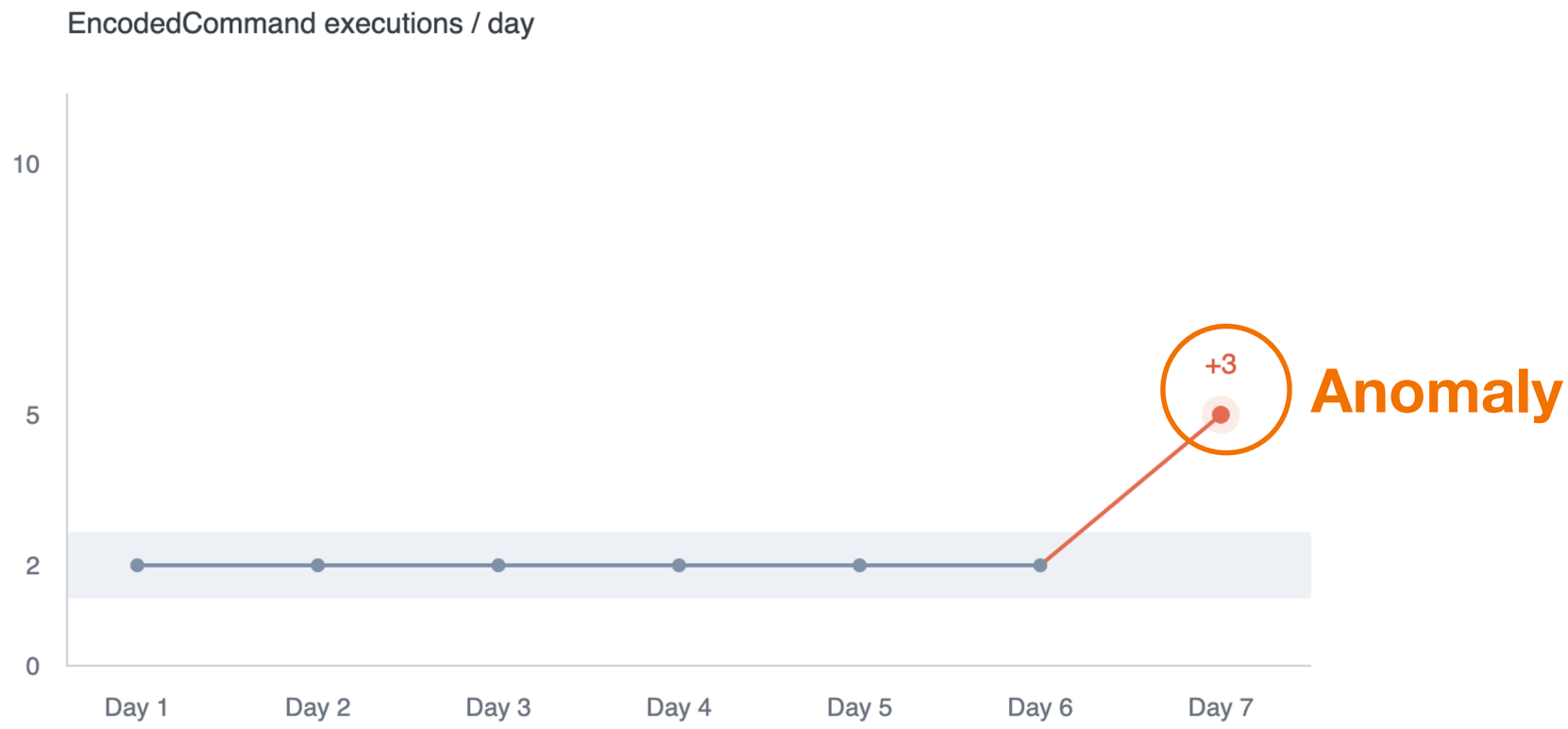
- Loose Correlation

  ↳ Technique A **OR** Technique B **OR** Technique C
  Unique_Count (Technique_ID) by Host
  Where Unique_Count >=2

  - Scalable
  - Easier to change threshold as your environment changes
  - Can detect multiple attack paths at the same time

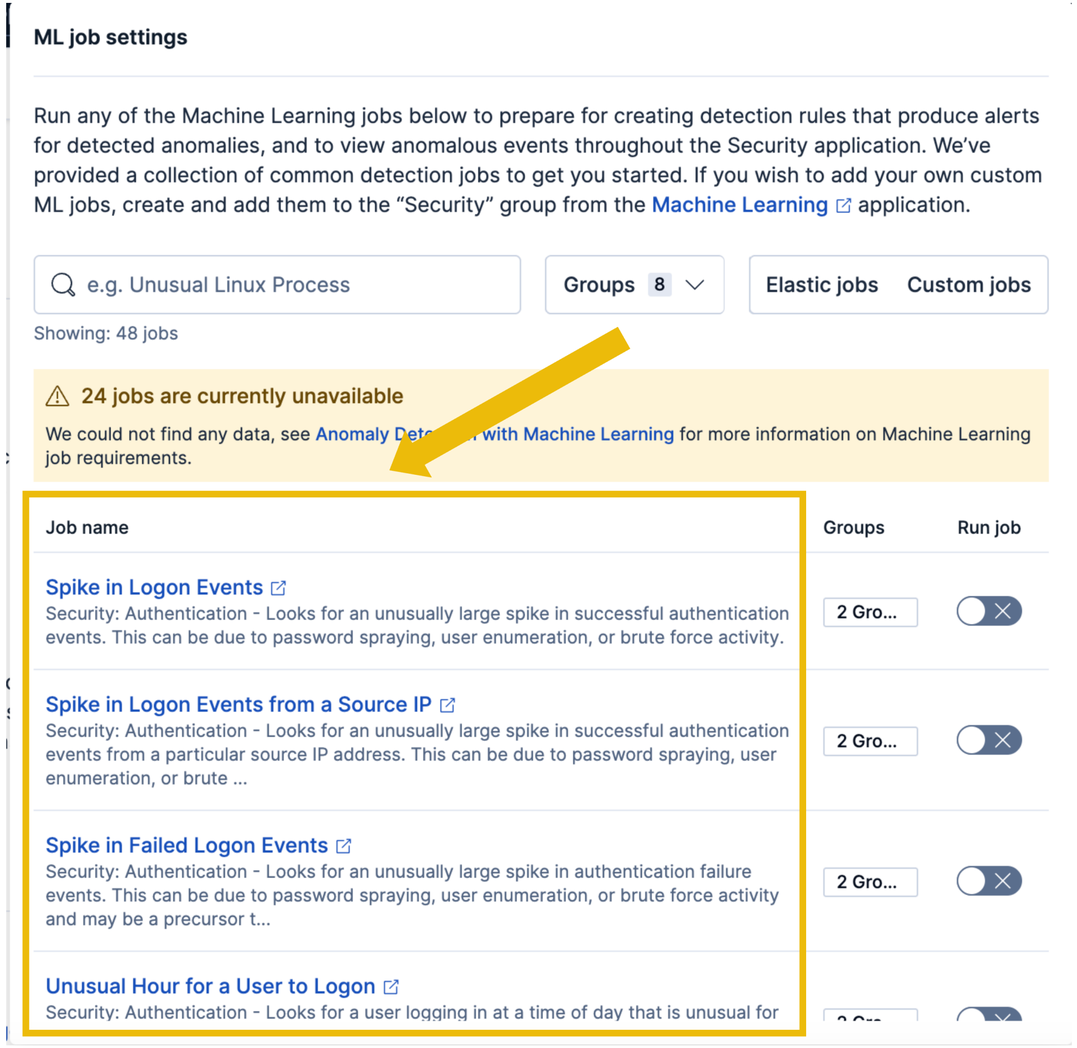
Anomaly Detection Rules

Learn a baseline of normal activity for a user, host, or network, then alert when something deviates far enough from it.



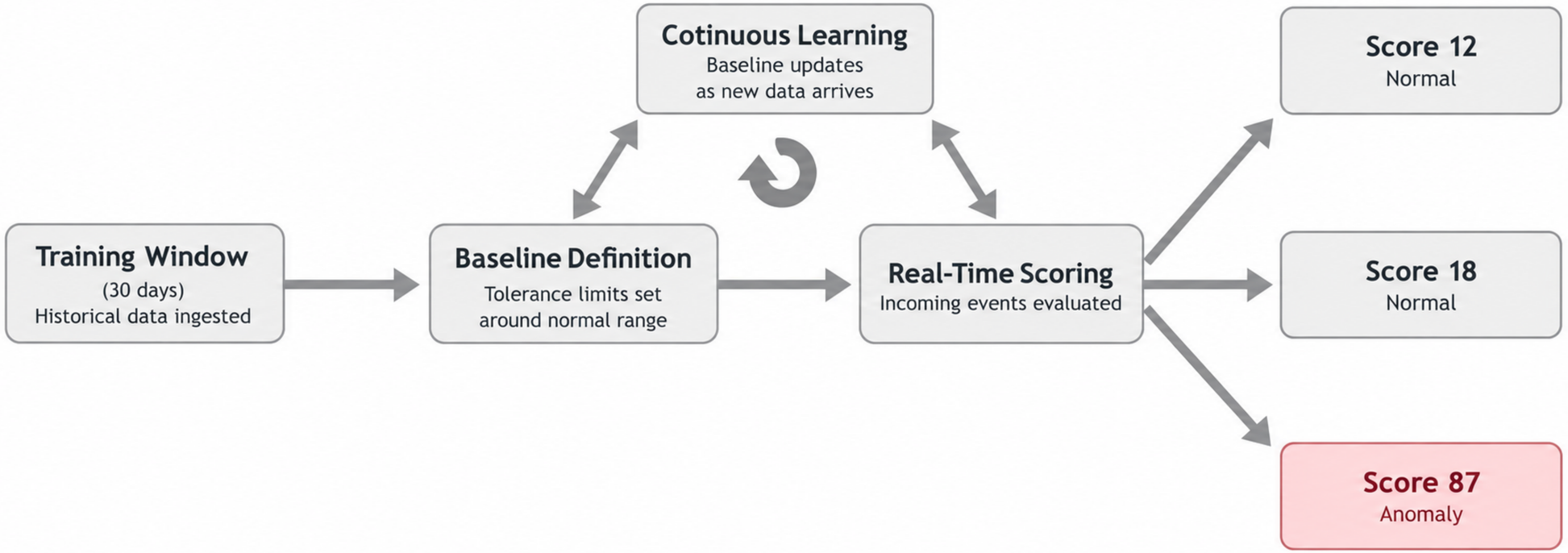
Anomaly Detection Rules

How it works (Elastic Example)



Anomaly Detection Rules

How it works (Elastic Example)



Anomaly Detection Rules

Challenge to Maintain

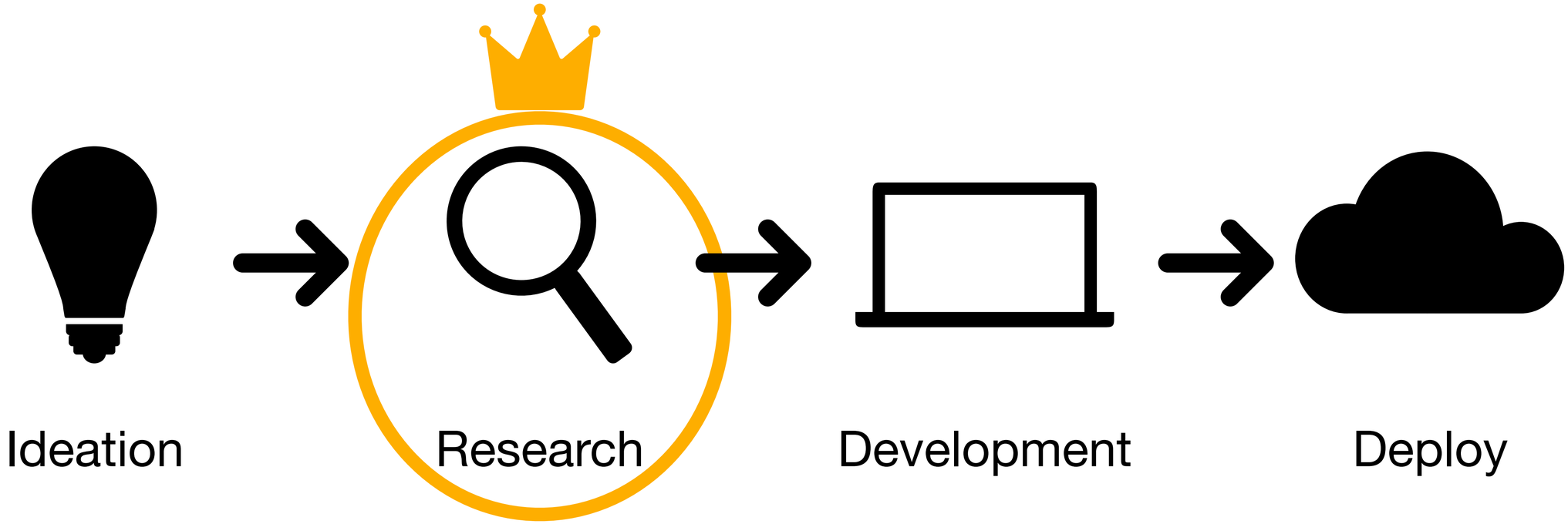
- High cost of implementation
- Requires multiple tuning iterations
- Long period to start working

Can be a solution for ambiguous techniques

TL;DR: **Loose Correlations FTW**

The Research Process

Research is the way!



Thanks! Lab Time :)

Questions?